

# Security+ 4.3 · Threat Intelligence

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.3 — Threat Intelligence (4:46)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

---

**Resumo Executivo da Aula:** Inteligência de ameaça: OSINT (informação ABERTA sobre o atacante); feed de terceiro (CrowdStrike, RecordedFuture); compartilhamento da comunidade (FS-ISAC); dark web (cuido do dado vazado). Resultado: IOCs (IP, hash, domínio).

## Highlights que a prova cobra

---

- OSINT: informação pública que revela o risco ANTES do ataque
- Threat feed + SIEM/EDR = bloqueio e detecção

## Dicas de prova & Cenários Típicos

---

- 'publicly available information used for intelligence'=OSINT

**Cenário clássico de exame:** 'empresa coleta informação do dark web sobre senha vazada' = threat intelligence.

## Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 4.3 — Threat Intelligence)

**Por que este aprofundamento é cobrado no exame?** O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **SIEM:** Security Information and Event Management: Plataforma centralizada que coleta, correlaciona e analisa logs e eventos de segurança de servidores, firewalls e endpoints em tempo real.
- **EDR:** Endpoint Detection and Response: Ferramenta instalada em estações e servidores que monitora comportamentos suspeitos, detecta ameaças avançadas e permite isolamento e contenção remota imediata.

### **Armadilhas e Pegadinhas Clássicas da Banca:**

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

## Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

**1. O framework NIST CSF organiza a segurança em 5 funções. Quais são?**

- A)** Instalar, Atualizar, Testar, Auditar, Arquivar
- B)** Identificar, Proteger, Detectar, Responder, Recuperar
- C)** Planejar, Fazer, Checar, Agir, Revisar
- D)** Prevenir, Punir, Prever, Provar, Publicar

**2. Cenário corporativo (Threat Intelligence):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'OSINT: informação pública que revela o risco ANTES do ataque'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: OSINT: informação pública que revela o risco ANTES do ataque...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**3. Cenário corporativo (Threat Intelligence):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'Threat feed + SIEM/EDR = bloqueio e detecção'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Threat feed + SIEM/EDR = bloqueio e detecção...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**4. Cenário corporativo (Threat Intelligence):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'publicly available information used for intelligence'=OSINT'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'publicly available information used for intelligence'=OSINT...

**5. Cenário corporativo (Threat Intelligence):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'empresa coleta informação do dark web sobre senha vazada' = threat intelligence.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'empresa coleta informação do dark web sobre senha vazada' = threat intelli...

**6. Cenário corporativo (Threat Intelligence):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'OSINT: informação pública que revela o risco ANTES do ataque'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: OSINT: informação pública que revela o risco ANTES do ataque...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**7. Cenário corporativo (Threat Intelligence):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'Threat feed + SIEM/EDR = bloqueio e detecção'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Threat feed + SIEM/EDR = bloqueio e detecção...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**8. Cenário corporativo (Threat Intelligence):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: "publicly available information used for intelligence"=OSINT'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'publicly available information used for intelligence'=OSINT...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**9. Cenário corporativo (Threat Intelligence):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: "empresa coleta informação do dark web sobre senha vazada" = threat intelligence.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'empresa coleta informação do dark web sobre senha vazada' = threat intelli...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**10. Cenário corporativo (Threat Intelligence):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'OSINT: informação pública que revela o risco ANTES do ataque'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: OSINT: informação pública que revela o risco ANTES do ataque...

## GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

### 1) B — Identificar, Proteger, Detectar, Responder, Recuperar.

✓ **Por que está certa:** O NIST Cybersecurity Framework (CSF) 2.0 organiza as atividades de segurança cibernética em cinco funções principais: Identificar, Proteger, Detectar, Responder e Recuperar. Essas funções representam o ciclo de vida completo da gestão de riscos cibernéticos. 'Identificar' envolve entender o contexto organizacional, ativos, riscos e vulnerabilidades. 'Proteger' abrange a implementação de salvaguardas para garantir a entrega de serviços críticos. 'Detectar' define as atividades para identificar a ocorrência de eventos de segurança cibernética. 'Responder' compreende as ações tomadas após a detecção de um incidente. 'Recuperar' foca na restauração de capacidades ou serviços que foram prejudicados. Essa estrutura é amplamente adotada e exigida no domínio de Arquitetura e Design de Segurança da certificação CompTIA Security+ (SY0-701), especificamente no objetivo 2.1, que trata de frameworks e diretrizes.

#### ✗ Por que as outras estão erradas:

- *Instalar, Atualizar, Testar, Auditar, Arquivar:* Esses termos descrevem etapas genéricas de um processo operacional de TI, como um ciclo de vida de software ou de gestão de patches, mas não constituem as funções do NIST CSF. 'Instalar' e 'Atualizar' referem-se à implantação e manutenção de sistemas; 'Testar' é uma atividade de verificação; 'Auditar' é uma avaliação de conformidade; e 'Arquivar' é uma prática de retenção de dados. Nenhuma dessas ações corresponde às funções estratégicas de alto nível definidas pelo NIST CSF, que são orientadas a riscos e não a tarefas táticas.
- *Planejar, Fazer, Checar, Agir, Revisar:* Essa é uma variação do ciclo PDCA (Plan-Do-Check-Act), utilizado em sistemas de gestão da qualidade e melhoria contínua, como a ISO 9001. Embora o NIST CSF possa ser integrado a processos de melhoria contínua, suas cinco funções não são 'Planejar, Fazer, Checar, Agir, Revisar'. O PDCA é um modelo genérico de gestão, enquanto as funções do CSF são específicas para segurança cibernética e possuem escopo e definições próprias. A inclusão de 'Revisar' como quinta etapa é uma distorção, pois o PDCA clássico tem quatro etapas.
- *Prevenir, Punir, Prever, Provar, Publicar:* Esses termos não fazem parte de nenhum framework reconhecido de segurança cibernética. 'Prevenir' é um objetivo, mas não uma função do CSF; 'Punir' é uma ação disciplinar ou legal, não uma função de segurança; 'Prever' é uma meta aspiracional, não uma função operacional; 'Provar' e 'Publicar' são ações de auditoria e comunicação, respectivamente, mas não compõem a estrutura do NIST CSF. Essa alternativa mistura conceitos de justiça, previsão e divulgação, sem qualquer relação com as funções oficiais do framework.

### 2) A — Implementar a solução correspondente: OSINT: informação pública que revela o risco ANTES do ataque....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Threat Intelligence): OSINT: informação pública que revela o risco ANTES do ataque.

#### ✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**3) C — Implementar a solução correspondente: Threat feed + SIEM/EDR = bloqueio e detecção....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Threat Intelligence): Threat feed + SIEM/EDR = bloqueio e detecção.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**4) D — Implementar a solução correspondente: 'publicly available information used for intelligence'=OSINT....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Threat Intelligence): 'publicly available information used for intelligence'=OSINT.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**5) D — Implementar a solução correspondente: 'empresa coleta informação do dark web sobre senha vazada' = threat intelli....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Threat Intelligence): 'empresa coleta informação do dark web sobre senha vazada' = threat intelligence..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**6) C — Implementar a solução correspondente: OSINT: informação pública que revela o risco ANTES do ataque....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Threat Intelligence): OSINT: informação pública que revela o risco ANTES do ataque.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**7) C — Implementar a solução correspondente: Threat feed + SIEM/EDR = bloqueio e detecção....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Threat Intelligence): Threat feed + SIEM/EDR = bloqueio e detecção.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**8) A — Implementar a solução correspondente: 'publicly available information used for intelligence'=OSINT....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Threat Intelligence): 'publicly available information used for intelligence'=OSINT.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**9) B — Implementar a solução correspondente: 'empresa coleta informação do dark web sobre senha vazada' = threat intelli....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Threat Intelligence): 'empresa coleta informação do dark web sobre senha vazada' = threat intelligence..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**10) D — Implementar a solução correspondente: OSINT: informação pública que revela o risco ANTES do ataque....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Threat Intelligence): OSINT: informação pública que revela o risco ANTES do ataque.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.